

TD03 — Revue contradictoire d'une API

Séance S10 · 90 min · C06, C08, C09 · Jeu de rôles

Dossier

Une API de tickets expose :

```
POST /api/login          -> access_token, user
GET /api/tickets/{id}    -> id, owner_id, title, internal_note
PATCH /api/users/me     <- JSON libre
POST /api/tickets/export <- {"format":"pdf","callback_url":"..."}
```

Le proxy fait confiance à tout `X-Forwarded-For`, les erreurs de validation retournent la stack trace, le quota « 100/min » n'a pas de clé documentée et le token reste valide 24 h sans révocation. Le schéma OpenAPI accepte `additionalProperties: true`.

Rôles

- équipe produit : préserver les cas d'usage et expliquer les contraintes ;
- équipe sécurité : construire des hypothèses testables et prioriser ;
- équipe exploitation : juger déploiement, logs, quota et rollback ;
- observateur : relever affirmations sans preuve et décisions.

Travail demandé

1. Établissez en 15 min l'inventaire méthode/objet/sujet/propriétés/erreurs.
2. Écrivez en 20 min huit tests sous forme Given/When/Then, dont 200/401/403, mass assignment, champ excessif, quota avec vrai 429, callback simulé et forwarded header.
3. Négociez en 20 min un contrat corrigé : schémas fermés, vues de réponse, autorisation objet, TTL/révocation, clé de quota, erreurs et trust proxy.
4. Définissez en 15 min six événements de journal avec champs utiles et interdits; aucun token/cookie/password.
5. Faites une revue contradictoire de 10 min : chaque équipe doit réfuter une hypothèse de l'autre par une preuve attendue.
6. Rendez en 10 min un ordre de correction P0/P1/P2 avec dépendances et rollback.

Barème /20

Critère	Points
Inventaire et frontières sujet/objet/propriété	5
Tests observables, y compris négatifs	6
Contrat corrigé cohérent	5
Logs, priorisation et qualité du débat	4

Les tests restent conceptuels ou dirigés vers ShopLab local; aucune URL externe n'est autorisée.